CYS 410: SECURITY AND RISK MANAGEMENT PRACTICES

MS. NANYANGWE L.R

nanyangweleah@gmail.com

0967203891 (WHATSAPP)

11. THREAT ASSESSMENT PROCESS

- Will look at:
  - Threat classification models
  - Cyber threat intelligence analysis
  - Incident response planning

THREAT CLASSIFICATION MODELS

- Threat classification models help organizations categorize and prioritize threats based on their nature, source, and potential impact.
  - These models provide a framework for understanding the characteristics of different threats and guide decision-making when it comes to risk mitigation and response planning.

THREATS ARE CLASSIFIED ACCORDING TO:

- Threat Actor
- Threat Type
- Impact and Likelihood

THREAT ACTOR

- Classifying threats based on the actors who carry out the attack, such as:
  - **Hacktivists**: Individuals or groups motivated by political or social causes.
  - **Cybercriminals**: Individuals or groups who engage in criminal activities like stealing sensitive data or financial fraud.
  - **State-Sponsored Actors**: Threats originating from government-backed organizations targeting other nations or businesses for espionage, cyber warfare, or strategic advantage.
  - **Insiders**: Employees or contractors who intentionally or unintentionally cause harm by exploiting their access to systems or data.

THREAT TYPE

- Classifying threats based on their nature, such as:
  - **Malware**: Viruses, worms, ransomware, and trojans that compromise system security.
  - **Phishing**: Deceptive attempts to trick users into revealing personal or sensitive information.
  - **Denial of Service (DoS) Attacks**: Attacks designed to overload systems or networks, making them unavailable.
  - **Advanced Persistent Threats (APTs)**: Prolonged and targeted attacks aimed at infiltrating systems and maintaining long-term access.

IMPACT AND LIKELIHOOD

- Categorizing threats based on their likelihood of occurring and the potential damage they could cause.
  - Threats that are highly likely and could cause significant damage are prioritized for response.

COMMON THREAT CLASSIFICATION MODELS

- **STRIDE Model**: Used for identifying and categorizing threats based on specific attack types:
  - Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege.
- **OWASP Top 10**: A list of the most critical security risks to web applications, which includes threats like injection attacks, broken authentication, and sensitive data exposure.

CYBER THREAT INTELLIGENCE ANALYSIS

- Cyber threat intelligence (CTI) involves gathering, analysing, and interpreting information about current or emerging threats.
- CTI enables organizations understand better the techniques, and procedures used by cyber adversaries and proactively defend against these threats.

SOURCES OF CYBER THREAT INTELLIGENCE

- **Open-Source Intelligence (OSINT)**: Publicly available data, including social media, forums, and websites.
- **Commercial Threat Intelligence Feeds**: Paid services that provide up-to-date information about known threats and vulnerabilities.

SOURCES OF CYBER THREAT INTELLIGENCE…

- **Internal Logs and Data**: Network traffic, system logs, and security information from within the organization that may reveal indicators of a cyber attack.
- **Government and Industry Collaborations**: Cybersecurity organizations, ISACs (Information Sharing and Analysis Centres **Impact and Likelihood**), and government bodies that share threat intelligence to improve national and industry-wide security.

THREAT INTELLIGENCE MODELS

- **Diamond Model of Intrusion Analysis**: A model that focuses on the relationship between adversary, infrastructure, capability, and victim to better understand and predict future attacks.
- **Kill Chain Model**: A model that outlines the stages of a cyber attack, from initial reconnaissance to exfiltration of data, allowing defenders to detect and disrupt attacks at various stages.

INCIDENT RESPONSE PLANNING

- Incident response (IR) planning is the process of developing and implementing a structured approach to addressing and managing the aftermath of a security breach or cyber attack.
  - Having a well-defined incident response plan (IRP) allows organizations to minimize the impact of a security incident, recover quickly, and prevent further damage.

KEY COMPONENTS OF AN INCIDENT RESPONSE PLAN (IRP)

1. **Preparation**: Establishing the necessary infrastructure, tools, and teams to effectively respond to incidents.
   - This includes forming an incident response team (IRT), creating communication protocols, and ensuring staff are trained.
2. **Identification**: Detecting potential security incidents using monitoring tools, threat intelligence, and analysis of suspicious activity or anomalies in systems.

KEY COMPONENTS OF AN INCIDENT RESPONSE PLAN (IRP)…

3. **Containment**: Implementing strategies to limit the spread and impact of the incident, such as isolating affected systems or shutting down compromised network segments.
4. **Eradication**: Removing the root cause of the incident, such as malware, vulnerabilities, or unauthorized access, to prevent the incident from reoccurring.

KEY COMPONENTS OF AN INCIDENT RESPONSE PLAN (IRP)…

5. **Recovery**: Restoring systems and services to normal operation.
    - This includes data restoration, patching systems, and ensuring that security controls are working as expected.
6. **Lessons Learned**: Conducting a post-incident analysis to review what went wrong, what went right, and how the organization can improve its security posture and incident response processes in the future.

INCIDENT RESPONSE FRAMEWORKS

- **NIST SP 800-61**: A guide for computer security incident handling and response, outlining procedures for identifying, managing, and recovering from security incidents.
- **SANS Incident Handling Process**: A five-step incident handling approach, similar to the NIST model, focused on preparation, identification, containment, eradication, and recovery.

INCIDENT RESPONSE TEAM (IRT)

- **Roles and Responsibilities**: The IRT typically includes technical experts, communication specialists, legal advisors, and management representatives who are responsible for leading the response effort.
- **Collaboration**: Incident response teams work closely with external stakeholders, such as law enforcement, third-party vendors, and public relations teams, to manage and mitigate the impact of the incident.

12.VULNERABILITY ISSUES

- Vulnerability management is a critical aspect of cybersecurity.
- It involves identifying, assessing, and mitigating vulnerabilities that could potentially be exploited by attackers.
- This process ensures that networks and systems are secure and protected against various security threats.

  - Common vulnerabilities in networks and systems
  - Security testing and ethical hacking
  - Patching and remediation techniques

1. COMMON VULNERABILITIES IN NETWORKS AND SYSTEMS

- Vulnerabilities can exist at various levels of an organization's infrastructure, from hardware to software, and even in the way users interact with systems.

NETWORK VULNERABILITIES

- **Open Ports**: Unused or unnecessary open ports on networked devices can provide attackers with unauthorized access to systems.
- **Weak Network Protocols**: Using outdated or insecure protocols like FTP (File Transfer Protocol) instead of more secure alternatives like SFTP can expose systems to attack.

NETWORK VULNERABILITIES…

- **Man-in-the-Middle (MITM) Attacks**: Attackers can intercept communications between two parties and alter or steal sensitive information if network traffic is not properly encrypted.
- **Denial of Service (DoS) Vulnerabilities**: Systems vulnerable to excessive traffic or resource requests may be targeted for DoS attacks, causing them to crash or become unresponsive.

SYSTEM VULNERABILITIES

- **Buffer Overflows**: A buffer overflow occurs when a program writes more data to a buffer than it can handle, allowing attackers to overwrite memory, potentially gaining control over the system.
- **Privilege Escalation**: Vulnerabilities in systems can allow attackers to gain elevated access to restricted areas, escalating their privileges beyond what was originally authorized.

SYSTEM VULNERABILITIES…

- **Weak Authentication Mechanisms**: Insufficient or weak authentication measures (like weak passwords or lack of multi-factor authentication) can make it easier for attackers to gain unauthorized access to systems.
- **Outdated Software**: Older software versions may contain unpatched vulnerabilities, which attackers can exploit if security patches are not applied regularly.

WEB APPLICATION VULNERABILITIES

- **SQL Injection**: Attackers can inject malicious SQL queries into a web application, allowing them to access and manipulate database data.
- **Cross-Site Scripting (XSS)**: Malicious scripts can be injected into web pages viewed by other users, leading to unauthorized access or information theft.
- **Cross-Site Request Forgery (CSRF)**: Attackers trick users into making unwanted requests, leading to actions being performed on their behalf without their consent.

2. SECURITY TESTING AND ETHICAL HACKING

- Security testing is an essential component of identifying vulnerabilities and weaknesses in systems, networks, and applications.
- Ethical hacking involves conducting penetration tests and security assessments to uncover vulnerabilities before malicious attackers can exploit them.

SECURITY TESTING METHODS:

- **Vulnerability Scanning**: Automated tools are used to scan networks and systems for known vulnerabilities.
- These tools compare system configurations and software versions against a database of known vulnerabilities.

SECURITY TESTING METHODS:

- **Penetration Testing (Pen Testing)**: Ethical hackers simulate real-world attacks to identify potential entry points and vulnerabilities in a system.
- This proactive approach helps organizations assess the strength of their defences and respond to weaknesses before they are exploited.
  - **Black-Box Testing**: Testers have no prior knowledge of the target system and attempt to exploit it as an external attacker would.
  - **White-Box Testing**: Testers have full knowledge of the system's architecture and attempt to identify vulnerabilities from an insider's perspective.
  - **Gray-Box Testing**: A combination of both black-box and white-box testing where the tester has partial knowledge of the system.

SECURITY TESTING METHODS

- **Static Application Security Testing (SAST)**: Analysing the source code of an application to find vulnerabilities, errors, or weaknesses before the application is even run.
- **Dynamic Application Security Testing (DAST)**: Testing running applications in real-time to find vulnerabilities that may only appear when the application is in use.

ETHICAL HACKING

- Ethical hackers, also known as "white-hat hackers," play a crucial role in identifying and fixing vulnerabilities.
- These professionals work with organizations to uncover potential weaknesses and provide recommendations for strengthening security measures.

TOOLS USED BY ETHICAL HACKERS

- **Nmap**: A network exploration tool that helps identify open ports, active devices, and services running on a network.
- **Metasploit**: A penetration testing framework used to identify and exploit vulnerabilities in systems.
- **Wireshark**: A network protocol analyser that allows attackers to monitor network traffic and look for sensitive information.
- **Burp Suite**: A toolset for testing web application security, including vulnerability scanning and manual testing.

3. PATCHING AND REMEDIATION TECHNIQUES

- Patching and remediation are essential practices for securing systems and networks by fixing identified vulnerabilities.
- Regular patching of software and hardware is necessary to prevent attackers from exploiting known weaknesses.

PATCHING

- **Patch Management**: This involves the process of identifying, testing, and applying patches (software updates) to systems, applications, and network devices to correct security flaws and vulnerabilities.
  - **Automated Patch Management**: Tools like WSUS (Windows Server Update Services) or third-party patch management systems help organizations automate patch deployment.
  - **Critical vs. Non-Critical Patches**: Critical patches address vulnerabilities that can be exploited immediately or cause major damage, while non-critical patches address minor or less immediate issues.
  - **Zero-Day Patches**: These patches address vulnerabilities that are being actively exploited by attackers before the software vendor releases a fix. Zero-day vulnerabilities are especially dangerous because there is no time to prepare for them.

REMEDIATION

- **Remediation Planning**: After identifying vulnerabilities, organizations should develop a remediation plan that includes actions for fixing, mitigating, or removing vulnerabilities.
  - **Prioritization**: Not all vulnerabilities are equally dangerous. Critical vulnerabilities should be addressed immediately, while less critical vulnerabilities can be mitigated over time.
  - **Backup and Recovery**: Before applying patches or making changes to systems, it is important to create backups to avoid data loss in case the patch introduces new issues.

BEST PRACTICES FOR REMEDIATION

- **Layered Défense**: Implement multiple layers of security controls to ensure that even if one control fails, others can still protect the system.
- **Least Privilege Principle**: Limit user access and permissions to only what is necessary for them to perform their job functions.
- **Network Segmentation**: Dividing networks into smaller segments helps prevent lateral movement in case of a breach and makes it easier to isolate and mitigate incidents.

13. RISK PROCESS

- The **risk process** is a crucial part of risk management, particularly in the fields of cybersecurity and organizational security.
- It encompasses the identification, evaluation, response, monitoring, and reporting of risks that can affect the success of projects, business operations, or IT infrastructure.
- An effective risk process helps organizations minimize threats and maximize opportunities while ensuring that security, compliance, and operational objectives are met.
- Risk identification and evaluation
- Risk response strategies
- Risk monitoring and reporting

1. RISK IDENTIFICATION AND EVALUATION

- Risk identification is the first step in the risk management process and involves recognizing potential threats that could negatively impact the organization. Evaluation involves analysing the identified risks to understand their potential impact and likelihood.

RISK IDENTIFICATION:

- **Internal Risks**: Risks that originate within the organization.
  - These may include human errors, system failures, insider threats, and inefficient processes.
- **External Risks**: Risks from outside the organization, such as cyberattacks, natural disasters, regulatory changes, or market shifts.

RISK IDENTIFICATION:

- **Technological Risks**: Risks associated with using new or untested technology, software vulnerabilities, or issues caused by outdated systems.
- **Human Factor Risks**: Risks resulting from human behaviour, such as errors, negligence, social engineering, or insider threats.

RISK EVALUATION

Once risks are identified, they are evaluated based on two key factors:

- **Likelihood**: The probability that a risk will occur. This can range from low to high, depending on the historical frequency of similar risks or the vulnerability of systems.
- **Impact**: The potential consequences if a risk materializes. These can include financial losses, reputational damage, legal consequences, and operational disruptions.

RISK MATRIX

A risk matrix is often used to evaluate risks. It visually represents the likelihood and impact of each risk on a grid, helping prioritize risks for mitigation.

- **High Likelihood / High Impact**: These are the most critical risks and should be addressed first.
- **High Likelihood / Low Impact**: Risks that occur frequently but have low impact should be mitigated, though they are not as urgent as high-impact risks.
- **Low Likelihood / High Impact**: These are rare but potentially devastating risks that need to be planned for.
- **Low Likelihood / Low Impact**: These risks may be ignored or monitored depending on their significance.

RISK RESPONSE STRATEGIES

- After risks are identified and evaluated, response strategies must be developed to manage and mitigate them.
- There are several strategies for responding to risks, which depend on the nature of the risk and its potential impact.

RISK RESPONSE STRATEGIES

- **Risk Avoidance**: This strategy involves eliminating the risk altogether by changing plans, procedures, or actions.
  - It might involve discontinuing a project, altering a process, or avoiding certain technologies or suppliers.
- **Risk Mitigation**: In this approach, steps are taken to reduce the likelihood or impact of the risk. This could include implementing security controls, applying patches, or improving training to prevent human errors.
  - Example: Installing firewalls and intrusion detection systems to mitigate the risk of cyberattacks.

RISK RESPONSE STRATEGIES

- **Risk Transfer**: This strategy involves transferring the risk to another party, often through insurance or outsourcing. For instance, outsourcing data storage to a third-party provider with strong security measures.
  - Example: Purchasing cyber insurance to transfer the financial risk of a data breach.
- **Risk Acceptance**: Sometimes, organizations may choose to accept the risk if the cost of mitigation is too high compared to the potential impact. This is typically used for low-impact or low-likelihood risks.
  - Example: Accepting the risk of a potential minor downtime due to maintenance on non-critical systems.

RISK RESPONSE PLANNING

- Develop specific action plans for each identified risk, outlining steps to reduce the risk or respond if it occurs.
- Assign responsibilities for executing the plan and establishing timelines for implementation.

RISK MONITORING AND REPORTING

- Ongoing monitoring and reporting are crucial for ensuring that risk management processes remain effective and that any changes in risk levels are promptly addressed.

RISK MONITORING

- **Continuous Risk Monitoring**: Risk monitoring involves continuously assessing the organization's security posture, identifying new risks, and evaluating the effectiveness of risk mitigation strategies.
- **Key Risk Indicators (KRIs)**: These are metrics used to monitor potential risk exposure. Examples include network traffic spikes (for cyberattacks) or employee turnover rates (for operational risks).
- **Risk Audits**: Periodic audits help assess whether the risk management strategies are effective. This can involve reviewing policies, checking for vulnerabilities, and validating mitigation actions.

RISK REPORTING

- **Risk Reports**: Regular reports provide updates on the status of risks, mitigation efforts, and any new risks that have been identified. These reports should be clear, concise, and provide actionable insights.
- **Stakeholder Communication**: Effective risk communication with stakeholders, including management, clients, and regulatory bodies, is key. Reports should highlight high-priority risks and the actions being taken to address them.
- **Risk Dashboard**: A risk dashboard is a tool for visualizing risk metrics and trends over time. It can provide executives and managers with a quick overview of current risk status and ongoing mitigation efforts.